

NivXRay Workspace — 360° Current-State Architecture & Functionality Audit

Type: READ-ONLY discovery. **Date:** 2026-02-15 (Session-20). **Scope:** Reverse-engineer the Workspace as it exists in the current repository. No code, UI, memory or architecture is modified. Where documentation, ADRs, PRDs, or comments disagree with implementation, the disagreement is called out explicitly. **Method:** Every claim is grounded in a file path + function/component. Anything not verifiable from code is marked `NOT VERIFIED FROM CODE`.

§0 Executive summary (10-line version)

1. **Two independent Workspace investigation paths exist today.** The primary Workspace "Investigate" button calls the **legacy rc2-orchestrator** path (`POST /api/decode/smart` → `smart_decoder.smart_decode + deterministic_best_decode`). Modern DIE / UI-DEF-02 authoritative surfaces only run on `POST /api/analyze` and `POST /api/die/*`, which the Workspace calls **secondarily and in parallel** for narrative / MITRE / trajectory panels.
 2. **Two MITRE technique surfaces are live simultaneously.** The legacy regex mapper `operations.mitre_map()` (backed by ~70+ `MITRE_HEURISTICS` regexes) still fires for saved cases produced through `/api/decode/smart`. The authoritative DIE-analyzer-catalogue surface (`analysis_core.get_authoritative_mitre` → `services.die.api.analyze` → `techniques[]`) is only reachable via `/api/analyze` and `/api/die/analyze`. The saved `PrevMode` case exhibits exactly this split — its persisted `mitre[]` comes from the legacy regex mapper (`Standalone long base64 blob`) and never touched the DIE catalogue.
 3. **UI-DEF-02 convergence is IMPLEMENTED but only WIRED to some entry points.** `/api/analyze` converges. `/api/die/analyze` returns the DIE catalogue directly. `/api/decode/smart` — the one the Workspace actually uses on submit — does NOT go through UI-DEF-02.
 4. **P2 Behavioral evidence (Sysmon E1/E3 + EVTX transport) IS shipped and PERSISTED** (Slice-1/2/3 + UI-Slice-1/2 + this session's UI-Slice-3 persistence). It is currently a **separate lane** — no correlation with the DIE decode chain beyond the client-side bidirectional MITRE highlight.
 5. **Verdict is produced by ≥3 different scorers.** `operations.risk_score()` (recalibrated), `evidence_extractor.build_verdict_card()`, and the DIE analyzer's implicit "techniques count + LOLBIN" via the same `risk_score`. There is no single verdict aggregator across the two Workspace paths.
 6. **The 14-tactic Attack Chain** (`TrajectoryDiagram.jsx`) is driven by `inlineStoryPreproc` OR `investigationObject.ice` synthesised by the canonical narrative bridge — it is NOT driven by the raw `/api/decode/smart` output. When the primary path returns no preprocessor, the Attack Chain falls back to synthesising nodes from `incident_behaviors`.
 7. **Persistence.** `workspace_cases` stores the full SSOT bundle inline PLUS a pointer (`ssot_ref`) to the content-addressable `investigation_ssot` store. `behavioral_evidence` (new this session) stores the exact ingest envelope, case-scoped.
 8. **Router registration:** 106 routers under `/api/*` are registered in `server.py`. Many are legacy / experimental (ADR-0009 counts: 84 ACTIVE-UI + 141 ACTIVE-API + 95 INTERNAL + 49 EXPERIMENTAL + 6 DEPRECATED + 4 DUPLICATE + 87 UNKNOWN = 466 total). This audit only enumerates the routes the Workspace actually calls.
 9. **Non-determinism sources:** TI feeds (bounded 500 ms), OSINT (bounded 20 s), AI describe (bounded 25/90 s, cached), timestamps in evidence-refs are absent (`evidence_refs` are content-addressable), MongoDB `_id` fields, `uuid.uuid4()` for case IDs. The core decode/analyze pipeline is deterministic; enrichment layers are not.
 10. **The single largest architectural gap** is the Workspace's continued reliance on the legacy `/api/decode/smart` primary path for user-facing verdicts, while all the modern authoritative work (UI-DEF-02 MITRE convergence, DIE catalogue, evidence-chain gate, LOLBIN extension) only fires on the parallel enrichment path. The `PrevMode` case's under-called `Suspicious 65` is a direct symptom of this gap.
-

§1 Workspace entry point — exact call chain

1.1 Frontend entry

- **File:** `frontend/src/pages/WorkspacePage.jsx` (4 316 LoC).
- **Component:** `WorkspacePage()` default export.
- **Route registration:** `frontend/src/App.js` mounts `WorkspacePage` at `/workspace` (verified by import graph, not shown here).
- **State:**
 - `input (useState)` — analyst-supplied raw text or file paste.
 - `currentCaseId (useState)` — set on `POST /cases/save` return or on `history/restore`. Passed to `BehavioralTimeline` (this session), `Find Related Cases` drawer.
 - `investigationObject`, `analystNarrative`, `inlineStoryPreproc`, `understanding` — populated by parallel API calls after submit.
 - `saveOnDecode / saveOnUpload` — controls auto-persist on success.
- **State persistence:** `useIdlePersist` (line 885) snapshots to `localStorage` on idle. Heavy fields (`investigationObject`, `analystNarrative`, `understanding`, `inlineStoryPreproc`) were removed from the snapshot in `Phase 5.W · P0.c` to prevent Chrome "Page Unresponsive" freezes.

1.2 Handlers

Grepped from `WorkspacePage.jsx`:

Handler	Line	Purpose
<code>onUpload</code>	~2390	File upload → <code>POST /api/upload</code>
<code>runInvestigate</code>	~1955	Primary "Investigate" button (used by <code>/investigate</code> UX flow) — calls <code>POST /api/die/investigation-results</code>
<code>runDecodeSmart</code>	~1340, ~1480, ~2115	<code>POST /api/decode/smart</code> — main decode path
<code>runUnderstanding</code>	~2035	<code>POST /api/die/understand?execute=true</code>
<code>runDieAnalyze</code>	~1440, ~2070	<code>POST /api/die/analyze</code>
<code>runDieNarrate</code>	~1450, ~2080	<code>POST /api/die/narrate</code>
<code>runAnalyzeAsync</code>	~1880	<code>POST /api/analyze/async</code>
<code>runDecodeChain</code>	~1155	<code>POST /api/decode/chain</code>
<code>runDecodeMagic</code>	~1675	<code>POST /api/decode/magic</code>
<code>runPlannerAdvise</code>	~908	<code>POST /api/planner/advise</code>
<code>runRecipe</code>	~876	<code>POST /api/recipe/run</code>
<code>saveCase</code>	~2300	<code>POST /api/cases/save</code>

restoreHistory	~630, ~820	GET /api/history/{id}
----------------	------------	-----------------------

1.3 Result hydration

After a submit, the Workspace typically fires **several requests in parallel** and merges results:

```
User clicks Investigate ■■■ POST /api/decode/smart → sets `analysis`, `chain`, `verdict_card`,
`mitre[]` ■■■ POST /api/die/understand → sets `understanding` ■■■ POST /api/die/analyze → sets
`dieEnvelope` (techniques[], lolbins[]) ■■■ POST /api/die/narrate → sets `analystNarrative` ■■■
POST /api/die/investigation-results (for narrative UX flow) → sets `investigationObject`
```

The "authoritative" data model the Workspace **displays** is therefore a client-side merge of results from **five independent backend routes**, not a single canonical response.

1.4 Refresh / reopen behaviour

- On page reload, `WorkspacePage` restores `input` and lightweight state from `localStorage`. Heavy fields (investigation object, narrative, understanding) are NOT restored client-side — they must be re-fetched via `/api/cases/{id}` when a case is reopened.
- This session's addition:** `BehavioralTimeline` now hydrates from `GET /api/behavioral/case/{case_id}` when `currentCaseId` is set. This is the only Workspace panel that currently re-fetches server-persisted evidence on mount.
- The **primary investigation object** does NOT auto-hydrate — the analyst must explicitly re-open the case from History.

§2 Input types — complete inventory matrix

Only accepted-vs-actually-handled combinations are listed. Support means an analyzer/adaptor that produces real MITRE/IOC/verdict output, not just a "detected" label.

Input Type	UI accepts	API endpoint(s)	Adapter / Router	Analyzer	Canonical repr	MITRE path	Verdict path	UI result	Status
Raw command line (any)	■	/api/decode/smart_decode /api/die/analyze	services/die/api::anal	DIE _analyze_silolbins[], services/die/api::anal	techniques[], lolbins[], ioclocs[]	■ Split: legacy regex on /decode/smart, DIE catalogue on /die/analyze and /api/analyze	risk_score	Full Workspace panels	■ LIVE (dual-path)
PowerShell	■	same	services/die/api::anal	PowerShell DIE	envelope	UI-DEF-02 (via /api/analyze only)	risk_score recalibrated	Attack Chain + Trajectory	■ LIVE
CMD / batch	■	same	services/die/api::anal	cmd.exe DIE	envelope	UI-DEF-02 (partial)	risk_score	Attack Chain	■ LIVE

Python	■	same	services/diagnose.py (limited)	AST-based	DIE envelope	UI-DEF-02	risk_score	■■ PARTIAL — no T1059.006, no T1620 (reflective load), no XOR pattern	■ PARTIAL	
JavaScript / VBS	■	same	javascript_ast.py vbscript_ast.py	AST-based	DIE envelope	UI-DEF-02	risk_score	Attack Chain		■ LIVE
Bash / shell	■	same	bash_ast.py	AST-based	DIE envelope	UI-DEF-02	risk_score	Attack Chain		■ LIVE
Sysmon XML	■ (Behavioral paste-in)	/api/behaviors	services/behavioral/sysevidence[]	Behavioral normalizer	per_event_surfaces, correlation (state Event-1 command lines only)	authenticative	■■ Behavioral evidence does NOT drive the primary verdict	Behavioral Timeline panel	■ LIVE	
EVTX binary	■ (Behavioral drop-in)	/api/behaviors	services/behavioral/evtxreader.py	Behavioral	same	same	same	■ LIVE (transport)		
Windows Event logs (non-Sysmon)	■■ classifier-only	—	services/ui/classifier.py recognizes the magic	—	InputKind.EVTX	—	—	UNsupported analyzer (routed as EVTX but no non-Sysmon adapter)	■ PARTIAL	
Syslog	■	—	classifier has no SYSLOG kind	—	—	—	—	UNsupported		
WMI	■	—	—	—	—	—	—	UNsupported		
CEF / LEEF	■	—	—	—	—	—	—	UNsupported		

JSON	■	/api/decode (via nixforge.investigation.ingress_gate)	apply_ingress_gate investigation.ingress_gate vendor JSON (Cisco XDR / CrowdStrike / Defender / SentinelOne / Sysmon / QRadar / Splunk) before extractors	—	—	Depends on normalised text content	PARTIAL (schema URLs are stripped so they aren't extracted as IOCs)	
NDJSON	■■	—	Classifier InputKind, JSON catches JSON but not multi-line NDJSON	—	—	Depends on ingress-gate	PARTIAL	
CSV / EDR CSV	■	/api/decode + /api/die/investigation + /api/die/narrate	services/die style column map results	acsv_edr.py + object.mitre merge	canonical narrative bridge → MITRE ids	risk_score	Full panels	■ LIVE (Phase 5.W)
Firewall logs	■	—	—	—	—	—	UNSUPPORTED	
DNS logs	■	—	—	—	—	—	UNSUPPORTED (Slice-4 LOCKED)	
Web / server logs	■	—	—	—	—	—	UNSUPPORTED	
Database logs	■	—	—	—	—	—	UNSUPPORTED	
EDR / XDR telemetry (non-Sysmon)	■■	/api/decode	ingress_gate normalises to text	text extractor	—	—	PARTIAL (text-only, no structured telemetry model)	
Email (.eml)	■■	/api/upload	input_route returns "email"	route_for() classifier has EMAIL_EML, EMAIL_MSG kinds but no analyzer wired	—	—	PARTIAL — routed but no email adapter	

PDF	■■	/api/uploadinput_route	■■ text returns "pdf"	■■ text extraction only (no PDF adapter under services/die/ beyond pdfplumber in requirements)	text extractor	text-derived	text-derived	Partial	PARTIAL
Office (DOCX/PPTX/XLSX)	■	/api/upload	ZIP text extractor (Phase 5.W)	canonical narrative rules	augmented via canonical_bridge	narrative-MIT (T1219/T1204.002/T1071/T1486/T1560)	Risk_score	Full panels	■ LIVE
PE binary	■■	/api/uploadinput_route	services/pe → "pe"	pe_analyzer.py header/section summary	—	—	—	Partial	PARTIAL — pe_analyze produces evidence but not wired to the verdict card
ELF / Mach-O / APK	■	classifier detects magic	—	—	—	—	—	UNSUPPORTED (classifier only)	
Archives (ZIP) / (ZIP/7z/RAR/ISO) (rest)	■ (ZIP) / ■■ (rest)	/api/uploadsafe_iter	zip members + P0-Security-Gate limits	zip members extract of members	—	—	—	■ LIVE (ZIP) / UNSUPPORTED (7z/RAR/ISO)	
URLs / IPs / domains / hashes (atomic IOCs)	■	/api/decodev2.investigatio	no-IOC fast-path	no-IOC guard (short-circuits decode)	investigation_block	limited_kind	—	Atomic-IOC report	■ LIVE
Pasted mixed text	■	/api/decode_looks_like	mixed input → services/die/preprocessor	mixed input decomposition chain envelope	via chain	risk_score	Full panels	■ LIVE	
Uploaded files (generic)	■	/api/uploadservices/files_store::FileStore	(GridFS + dedup)	uploaded by content-magic	—	—	—	■ LIVE	
STIX / OpenIOC / YARA / Sigma	■■	UIL /classify	—	—	—	—	—	PARTIAL (classified, not analyzed)	

Canonical narrative bridge	services/die/canonical_bridge.py:	Additional investigation results object.chain.steps[] synthesis + LOLBAS enrichment on /api/die/investigation-results
P2 Behavioral	services/behavioral/sysmon_adapter.py:	Sysmon E1/E3 canonical evidence, correlation, per-event MITRE (from Event-1 command lines only)
Canonical UIL entry	services/uil/canonical_entry.py::investigate_canonical	Only when NIVX_CANONICAL_UIL_INVESTIGATE=on (currently ON) — used by /uil/investigate (NOT the primary Workspace path)

Yes, ≥ 3 independent investigation pipelines currently coexist.

§4 Backend processing pipeline (per input class)

Focus on the primary Workspace flow — raw command-line paste → /api/decode/smart.

```
INPUT (str) ■ ▼ routers/ops.py::decode_smart ■ ■■■
nixxforge.investigation.ingress_gate::apply_ingress_gate ■ (vendor JSON telemetry normalisation)
■ ■■■ v2.investigation.pipeline::_atomic_ioc_kind ■ (atomic-IOC fast-path — bare
URL/IP/hash/filename returns immediately) ■ ■■■ analysis_core::deterministic_best_decode ■ ■ ■
■■■ rc22_adapter::try_orchestrator_first (RC2.2) ■ ■ ■ ■■■
_deterministic_best_decode_single_pass ■ ■■■ smart_decoder.smart_decode() [greedy chain] ■ ■■■
magic_decode() [branching search] ■ (returns the winner) ■ ■■■
evidence_extractor::build_verdict_card ■ ■ ■ ■■■ extract_iocs (regex extractor) ■ ■■■
mitre_map (LEGACY regex mapper) ■ ■■■ yara_lite_scan ■ ■■■ scan_lolbas ■ ■■■ risk_score(mitre,
yara, iocs, lolbas) ■ ■■■ services/canonical_evidence_recovery::recover_canonical_evidence_async
■ (produces ARB canonical_artifact projection) ■ ■■■ returns JSON envelope: {output, chain,
verdict_card, mitre[], iocs, lolbas, canonical_artifact, ...} Persistence (opt-in per submit):
POST /api/cases/save → workspace_cases + investigation_ssot (ssot_ref)
```

Stages that actually execute for a raw command:

Stage	Executes?	Module	Deterministic
Parse (language sniff)	■	services/die/api.py::detect_language	■
Normalize	■	ingress_gate (JSON only)	■
Decode	■	smart_decoder.smart_decode + magic_decode	■ (both bounded)
Recursive decode	■ (only on /api/die/analyze path)	services/die/recursive_decode.py	■
Discover artifacts	■	analysis_core::extract_iocs + services/die/ioc_semantic	■
Correlate	■■ partial	services/correlation_engine.py (used by IKG paths, not by /decode/smart)	■

TI / IOC	■ (bounded 500 ms)	analysis_core::lookup_ti_■■■ (external)	■■■ (external meta)
LOLBAS	■	services/die/lolbas.py + scan_lolbas	■
MITRE	■ but split	operations.mitre_map (regex) OR services/die/api::analyze (catalogue)	■
Verdict	■	operations.risk_score + evidence_extractor.build_verdict_card	■
Narrative	■ (parallel /die/narrate call)	services/die/narrative.py + canonical_narrative_enrichment	■
Report	■	routers/reports.py (/report/{fmt})	■ (locked by determinism CI)
Case / IKG	■ (persist) / ■■ (IKG shadow)	routers/cases.py (case) + IKG shadow via NIVX_FLAG_TRAJECTORY_ENGINE=shadow	■
UI	■	Workspace panels	■

§5 Analysis engines inventory

Engine	Location	Input	Output	Called by	MITRE?	Verdict?	Decoder?	Evidence producer?	Legacy?
smart_decobackend/smart_decoder		text	decoded layers	deterministic	■	■	■	■■ (layers only)	■ LEGACY
magic_decobackend/magic_decoder	(inferred from imports)	text	decoded branches	deterministic	■	■	■	■■	■ LEGACY
determinisbackend/analysis_core		lexer 326	winner 326 {smart, magic}	routers/op	■	■	■	■■	■ LEGACY
rc22_adaptbackend/rc22_adapter	(inferred)	text	pre-AST decode	deterministic	■	■	■	■	■ LEGACY (RC2.2)
services/dservices/die/api.py		text	DIE envelope	/api/die/analyze, get_authoritative_mitre	■	■ (returns evidence)	■■ (per-language AST)	■	■ MODERN
services/dservices/die/powercat		text	AST	analyze_single	■	■	■	■	■ MODERN
services/dservices/die/cmd_ast	same	cmd text	AST	same	■	■	■■	■	■ MODERN

services/tbackend/services/technical	services/technical	ids	reference by legacy paths	■	■	■	■■	■■ MIXED
services/abackend/services/artifact	services/artifact	info	(via evidence/)	—	—	—	■	■ MODERN
services/ibackend/services/investigation	services/investigation	decision-tree engine	UIL canonical entry	■■	■■	■	■	■ MODERN (SHADOW)
services/ibackend/services/evidence	services/evidence	correlated behaviour clusters	augment_investigation_results(enrich_clusters_in_place)	■	■	■	■	■ MODERN
services/ubackend/services/investigation	services/investigation	recognizer/capability catalogue	canonical	■■	■■	■	■	■ MODERN (SHADOW)
services/ubackend/services/any	services/any	classified + normalised	/api/UIL/*	■	■	■■	■■	■ MODERN
services/sbackend/services/investigation	services/investigation	session bundle	/UIL/investigate	—	—	■	■	■ MODERN
services/aservices/artifact	services/artifact	finger print hash	py(case save + IKG shadow)	■	■	■	■	■ MODERN
services/cservices/decoding	services/decoding	extending canonical artifact	re/api/decode/smart	■	■	■	■	■ MODERN
evidence_ebackend/evidence_ext	evidence_ext	verdict chain	ca/api/decode/smart, /api/analyze(via regex)	■	■	■	■	■■ MIXED
operationsbackend/operations	operations	py1280 hits	/api/decode/smart (via verdict card), /api/analyze (regex_extra only)	■	■	■	■■	■ LEGACY (regex)
operationsbackend/operations	operations	py1280 score	/api/analyze, verdict card path	■	■	■	■	■■ (recalibrated 2026-08-12)
services/rbackend/services/any	services/any	reasoning summary	re/api/cases/save	■	■	■	■	■ MODERN
services/sservices/ssot	services/ssot	Store.py stored ref	content-addressed GET /api/cases/{id}	■	■	■	■	■ MODERN (R28)

services/reasoning, services/session, services/uaie shadow subsystems	—	shadow verdicts	flagged with NIVX_FLAG_*=shadow	—	■■ (shadow)	—	■■	■ SHADOW
---	---	--------------------	---------------------------------------	---	----------------	---	----	-------------

§6 MITRE / ATT&CK architecture

6.1 Every mapper / resolver currently able to emit a technique

#	File / function	Input	Output	Technique source	Evidence gate	Tactic mapping	Caller	UI consumer
1	operations.py:mitre_m	text:mitre_m	[{id, technique, tactic}]	~70 regex heuristics in MITRE_HEURISTICS	■ NONE	inline in each row	evidence_extractor/api/analyze (as mitre_provenance.regex_extra)	Verdictor.build_verdict
2	services/die/api.py: techniques[]	die/api.py: techniques[]	[{id, name, tactic, evidence}]	Per-language AST detectors + DKP catalogue + _merge_lolbin_techniques + _apply_recursive_decode	Implicit (only fires when AST rule matches)	Per-technique meta in _TECHNIQUE	/api/die/analyze (direct), _get_authorization (upstream)	Legacy diagram, Attack_mitre Chain, Narrative
3	services/die/canonicalization.py: narrative_enrichment.py: matches	canonicalization.py: narrative_enrichment.py: matches	narrative_enrichment.py: matches	prose-narrative rules (T1219/T1204.002/T1071/T1486/T1003/T1566/...)	prose, not command	NARRATIVE_TECHNIQUE	canonicalization.py: /die/narrate	Analyst narrative
4	services/die/canonicalization.py: result + text	canonicalization.py: result + text	canonicalization.py: result + text	canonicalization.py: result + text	canonicalization.py: result + text	via meta	/api/die/analyze	Legacy
5	services/die/canonicalization.py: analyze_csv	canonicalization.py: analyze_csv	canonicalization.py: analyze_csv	canonicalization.py: analyze_csv	canonicalization.py: analyze_csv	inline	canonicalization.py: (auto for CSV), /die/narrate (for CSV)	Bridge Chain (CSV cases)
6	services/die/lolbin.py: hits	lolbin.py: hits	lolbin.py: hits	lolbin.py: hits	lolbin.py: hits	inline	services/die/analyze and _chain_to_envelope	Factory analyze_si
7	services/die/recursive.py: merge_evidence	recursive.py: merge_evidence	recursive.py: merge_evidence	recursive.py: merge_evidence	recursive.py: merge_evidence	T1140 = Defense Evasion	_apply_recursive_decode in DIE analyze	Recursive decode (via DIE)

8	services/behavioral/super_event_mitre[] (indirectly)	services/behavioral/super_event_mitre[] E1 CommandLine	services/behavioral/super_event_mitre[]	services/die/api/analyze (DIE catalogue)	via DIE catalogue	_authoritative in routers/behavioral/super_event_mitre[]	Behavioral Timeline mitre_technique_ids
9	services/die/api/analyze	mitre_evidence_chain list	mitre_evidence_chain mitre list	enforce_evidence_chain evidence_retrieval mandatory	preserves incoming tactic source/event_or_rule/observed_value	analysis_core/api/analyze	mitre_technique_ids
10	services/behavioral/super_event_mitre[]	mitre_evidence_chain list	mitre_evidence_chain mitre list	further regex/heuristic — used by some legacy routes	—	(varies)	(varies)
11	AI describe leg	LLM (Claude/GPT/Gemini)	mitre_technique_ids	mitre_techniques[] response	■ (marked source: "ai")	inline	/api/analyze/api/analyze (when result describe=true)

6.2 Authoritative surface vs legacy surface

- **Authoritative** (locked at UI-DEF-02, ADR-0010m/o/p): `analysis_core.get_authoritative_mitre` — feeds only from `services/die/api.analyze::techniques[]` through the P0.2 evidence-chain gate. Consumers: `/api/analyze mitre[]` output; the 14-tactic Attack Chain when reached through this path.
- **Legacy regex mapper**: `operations.mitre_map()`. Still fires inside `evidence_extractor.build_verdict_card` (used by `/api/decode/smart` and `/api/analyze/async`). On `/api/analyze` it is demoted to `mitre_provenance.regex_extra` (diagnostic only). On `/api/decode/smart` it is authoritative for the returned `mitre[]` and `verdict_card`.

6.3 "Can the same Workspace input reach two different mappers?"

Yes. Exact paths:

- Analyst pastes `python -c "exec(base64...)"` and hits Investigate.
- Frontend fires:
- `POST /api/decode/smart` → `evidence_extractor.build_verdict_card` → **operations.mitre_map (regex)** → emits T1027 (Standalone long base64 blob ...) only.
- `POST /api/die/analyze` → `services/die/api.analyze` → **DIE catalogue** → may emit any subset of T1027, T1059.006 (if Python AST fires), T1140 (if recursive decode peels), T1620 (currently absent), etc.
- `POST /api/analyze` (unused by primary Investigate but reachable) → `get_authoritative_mitre` → **DIE catalogue via gate** + `regex_extra` diagnostic.
- Workspace UI merges these client-side. Depending on which panel the analyst looks at, they see a different MITRE list.

The saved `PrevMode` case's `mitre[]` field contains only the regex-mapper result. This is direct evidence that the primary Workspace save path uses the legacy surface.

§7 Verdict architecture

7.1 Every verdict producer

Producer	Location	Signals used	Output
operations.risk_score()	backend/operations.py:332	mitre[], yara[], iocs, lolbas[]	{score, verdict, level}
evidence_extractor.build_verdict_card()	backend/evidence_extractor.py:524	input text + chain + is_shellcode flag + corruption flag	verdict_card {label, verdict, confidence, risk_score, reason, indicators, recommended_action, explainability}
verdict_projection.derive_risk_score()	backend/verdict_projection.py:10	verdict_card only	projected risk (Rule 15 · verdict_card is sole SoT)
AI verdict leg	/api/analyze (when use_ai_verdict=true)	LLM output	ai_verdict {...}
Shadow Verdict Engine v3	services/uaie (flag NIVX_FLAG_VERDICT_ENGINE_V3=shadow)	canonical evidence graph	■■ SHADOW — not surfaced to UI

7.2 Trace

```
INPUT ■ ▼ SIGNALS ■■■ mitre[] (from legacy regex OR DIE catalogue – depends on path) ■■■ yara[] (from operations.yara_lite_scan) ■■■ iocs{} (from operations.extract_iocs) ■■■ lolbas[] (from operations.scan_lolbas OR services/die/lolbas) ■ ▼ SCORING ■■■ operations.risk_score() → {score, verdict, level} weights: YARA sev + 5/mitre + 8/lolbin(cap 24) + 30 (lolbin+ext.IOC) + 8/high-signal-TTP(cap 24) + 10 (T1218.*) ■ ▼ VERDICT CARD ■■■ evidence_extractor.build_verdict_card(...) Adds: label, confidence (=score), reason, indicators list, explainability contributors, recommended_action string. ■ ▼ UI ■■■ SocVerdictPanel (primary card) ■■■ VerdictCard (compact) ■■■ FinalSummary (analyst brief)
```

7.3 Multiple verdict engines?

Yes. Legacy path uses risk_score → verdict_card. Shadow Verdict Engine v3 lives under services/uaie/* behind NIVX_FLAG_VERDICT_ENGINE_V3=shadow and is NOT surfaced. The AI describe leg produces an independent ai_verdict that is displayed separately.

§8 Evidence architecture

8.1 Canonical evidence schema (as it exists in code)

Two independent evidence-schema families coexist:

Family A · DIE / IUE / Canonical Investigation SSOT — used by modern paths: - Base: services/uaie/evidence.py, services/confidence_provenance.py, services/die/mitre_evidence_chain.py::_short_ref. - Record shape: {source, event_or_rule, field, observed_value, evidence_ref, confidence} where evidence_ref is a deterministic SHA-256 short-hash of the identifying tuple. - Persisted under: investigation_ssot collection (content-addressable) + inline in workspace_cases.ssot.

Family B · Behavioral evidence — P2 only: - Base: services/behavioral/sysmon_adapter.py. - Record shape: {evidence_type, process_guid, evidence_ref, raw_refs[], count, first_seen, last_seen, correlation_state, corroboration{}, ...} plus advisory subrecords (advisory=True, derivation=...). - Correlation states: RESOLVED / UNRESOLVED_DANGLING / AMBIGUOUS_PID_ONLY — tri-state, never fabricated. -

Persisted under: `behavioral_evidence` collection (this session · ADR-0010v).

8.2 Separation of concerns — does it hold?

Owner-locked separation from ADR-0023:

Role	Current implementation	Violates?
Evidence producer	Sysmon adapter, DIE analyzer catalogue, CSV/EDR analyzer, recursive-decode	■ No (Sysmon adapter is producer-only)
Interpreter	<code>services/die/canonical_bridge</code> , <code>canonical_narrative_enrichment</code>	■■ Some overlap with mapper role (adds MITRE from narrative prose)
Correlator	<code>services/correlation_engine.py</code> , <code>sysmon_adapter._correlate_network</code>	■ No
MITRE resolver	<code>get_authoritative_mitre</code> (<code>analysis_core.py</code>)	■ Single authoritative resolver
Verdict engine	<code>operations.risk_score + verdict_card</code>	■■ <code>verdict_card.indicators[]</code> also carries MITRE ids — light coupling

One notable violation of the "no MITRE outside the resolver" rule: `operations.mitre_map()` runs INSIDE the verdict-card builder (`evidence_extractor.build_verdict_card`), meaning the verdict engine still owns a MITRE mapper on the legacy path.

§9 Current P2 Behavioral architecture (implemented today)

9.1 Ingestion

- **XML path:** `POST /api/behavioral/sysmon` (`routers/behavioral.py`) → `services/behavioral/sysmon_adapter.py::normalize_sysmon_xml` (defusedxml XXE-safe, 512 KB cap `NIVX_SYSMON_MAX_BYTES`).
- **EVTX path:** `POST /api/behavioral/sysmon/evtx` → `services/behavioral/evtx_reader.py::decode_evtx_to_sysmon_xml` (python-evtx 0.8.1, 16 MiB `NIVX_EVTX_MAX_BYTES`, 10 000 records `NIVX_EVTX_MAX_RECORDS`) → hands wrapped `<Events>` to the SAME normalizer.
- **Persistence (this session):** `POST /api/behavioral/attach`, `GET /api/behavioral/case/{id}`, `DELETE /api/behavioral/case/{id}`, plus optional `case_id` on both ingest endpoints for auto-attach.

9.2 Canonical evidence records emitted

For Event 1 (Process Create): - Per-Data field: one evidence record with `evidence_ref`, `source: "sysmon.event1"`, `field`, `observed_value`, `confidence: "medium"`. - One `parent_child_pair` with `child_pid`, `parent_pid`, `child_image`, `parent_image`, `corroboration.{count, image_path, hashes, user_session, integrity_level, temporal_delta}`, `parent_child_uncorroborated: bool`. - Explicit limitations.`ppid_spoofing: T1134.004`.

For Event 3 (Network Connect): - Per-connection record with canonical IP (RFC 5952), `destination_class` (RFC1918/reserved), `protocol`, `initiated: bool` preserved, `RuleName`. - Deduplication on (`ProcessGuid`, `protocol`, `canon_dst_ip`, `dst_port`, `initiated`) → `count`, `first_seen`, `last_seen`, `raw_refs[]`. - Tri-state `correlation_state` linking to Event-1 `process_guid`. - Advisory (`confidence: "advisory"`) records for `hostname / *PortName` with `derivation: "sysmon_reverse_lookup"`.

9.3 Persistence contract (this session)

behavioral_evidence collection:

```
{ user_email, case_id, envelope (exact ingest response), attached_at, updated_at, adapter_history[<=20] }
```

Retrieval: GET /api/behavioral/case/{case_id} scoped on user_email + case_id → 404 if absent.

9.4 UI components

- frontend/src/components/investigation/BehavioralTimeline.jsx — reads envelope, renders E1/E3 rows, dedup badges, correlation-state chips, evidence inspector, MITRE handoff footer.
- frontend/src/components/investigation/TrajectoryDiagram.jsx — 14-tactic Attack Chain; consumes preprocessor, behaviors, and (client-side) techId field.
- **Bidirectional link:** window.CustomEvent("nivx:mitre-selected", {technique_id}) and window.CustomEvent("nivx:evidence-selected", {technique_ids}).

9.5 What is NOT implemented (P2)

- Slice-4: Sysmon Event 22 (DNS) — **LOCKED**.
- Slice-5: Sysmon Event 11 (File Create) — **LOCKED**.
- Cross-source correlation (Sysmon + firewall + DNS + endpoint) — not implemented.
- Non-Sysmon adapters: WMI, Syslog, firewall logs, DNS logs, EDR/XDR structured telemetry — none exist.
- Behavioral evidence does not participate in the primary verdict (only in the client-side highlight).
- Attack Chain auto-scroll on evidence click — **planned (Task 3, on hold)**.
- Source-agnostic contract audit — **planned (Task 4, on hold)**.
- Real EVTX fixture in the Slice-3 test — **planned (Task 2, on hold)**.

§10 Workspace UI component map

Component	File	Purpose	Data source	API called	Read/Write	Analysis or projection
WorkspacePage	pages/WorkspacePage.jsx	workspace page	all	many (see §1.2)	R/W	orchestrator
PageHeader / Header	components/Header.jsx, PageHeader.jsx	header	—	—	R	projection
OperationsPanel	components/OperationsPanel.jsx	operations panel	/operations	GET	R	projection
RecipePanel	components/RecipePanel.jsx	recipe panel	/recipe/run	POST	R/W	projection + submit
ThreatAnalysis	components/ThreatAnalysis.jsx	threat analysis + YARA panel	analysis state	via /analyze	R	projection

SocVerdictPanel / VerdictCard	components/SocVerdictCard.jsx	VerdictDisplay	investigation object	via /decode/smart	R	projection
AttackGraph	components/AttackGraph.jsx	AttackGraph	investigation object	via /die/investigation-results	R	projection
TrajectoryDiagram	components/investigation/TrajectoryDiagram.jsx	Attack Chain	inlineStoryPrepared OR investigationObject.ice	POST	R	projection + client MITRE grouping
BehavioralTimeline	components/investigation/BehavioralTimeline.jsx	P2 Evidence Timeline	/behavioral/* responses (transient) + /behavioral/case/{id} (persistent)	POST + GET	R/W	projection
AnalystNarrative	components/investigation/AnalystNarrative.jsx	analyst summary	analystNarrative	via /die/narrate	R	projection
InlineAttackStory	components/investigation/InlineAttackStory.jsx	attack chapters	investigationObject.attack_progression	/die/investigation-results	R	projection
InputUnderstandingPanel	components/investigation/UnderstandingPanel.jsx	classification output	understanding	via /die/understand	R	projection
AcquisitionPlan	components/investigation/AcquisitionPlan.jsx	acquisition plan	investigationObject.acquisition_plan	/die/investigation-results	R	projection
AcquisitionSummary / AcquisitionEvidenceList	same dir	acquisition detail	acquisition_summary (from case doc)	via GET /api/cases/{id}	R	projection
ExtractedArtifactsPanel	same dir	artifact list	investigationObject.artifacts	/die/investigation-results	R	projection (currently disabled via eslint-ignore)
ArtifactTracePanel	same dir	Artifact→Recognize chain	artifact_trace (from case doc)	via GET /api/cases/{id}	R	projection
TimelinePanel	same dir	Workspace-native chronological timeline	investigationObject.highconf_events	via GET	R	projection
QueryHuntPanel	same dir	build hunt query	/die/query	POST	R/W	projection + submit
InvestigationSessionGateway	same dir	shows session state	Session store	via /session/*	R	projection
WorkspaceDecoderFailureCard	same dir	fail-loud on decode error	error state	—	R	projection
OutputView / ShellcodeView / FinalSummary	components/	decoded output views	output, shellcode, analysis	via /decode/*	R	projection

ReportMenu	components/ReportMenu.jsx	reportMenu dropdown	/report/{fmt}	POST	R/W	submit
PanelErrorBoundary	components/PanelErrorBoundary.jsx	PanelErrorBoundary isolation		—	R	error boundary
GuidanceBanner	components/GuidanceBanner.jsx	contextBanner	derived from state	—	R	projection
CollapsibleSection / CollapsibleCard	components/investigation/containers/CollapsibleSection.jsx, CollapsibleCard.jsx	EX contains			R	layout
InvestigationFilter / InvestigationFilterBar	components/investigation/InvestigationFilter.jsx	Investigation filtering			R	filter state

Parent-child relationships: WorkspacePage is the root; all components/components/investigation/* are children mounted conditionally on input/analysis/investigationObject state. BehavioralTimeline is a sibling of TrajectoryDiagram under the Attack Chain collapsible section.

§11 Data contracts — request/response shapes

Only the contracts the Workspace actively uses are enumerated. Every contract below has been verified against the router source in /app/backend/routers/.

Endpoint	Method	Request	Response (key fields)	Producer	Consumer
/api/upload	POST	multipart file	filename, size, hashes {md5, sha1, sha256}, file_type, text, hex_dump, strings, content, archive_refused, file_id, route, dedup	routers/ops.py::workspace	workspace onUpload
/api/decode/smart	POST	{input}	{output, chain, verdict_card, mitre[], iocs, lolbas, canonical_artifact, ...}	routers/ops.py::workspace	workspace onDecode
/api/decode/chain	POST	{input, steps[]}	{output, chain, layer_trace}	routers/ops.py	RecipePanel
/api/decode/magic	POST	{input, max_depth, max_branches, top_n}	{best, branches[]}	routers/ops.py	MagicButton

/api/die/analyze	POST	{input, language?}	{result: {techniques[], lolbins[], iocs[], chain, preprocessor, canonical_augmented, ...}}	routers/die.py::die_analyze	ThreatAnalysis
/api/die/understand	POST	{input, execute?}	{understanding: {kind, plan[], execution_trace[], ...}}	routers/die.py::die_understand	UnderstandingPanel
/api/die/narrate	POST	{input}	{narrative: {executive_summary, analyst_summary, behavior_summary[], attack_progression[], recommended_actions[], sigma_hunts[], yara_ideas[], overall_assessment{}, mitre_matrix[]}}	routers/die.py::die_narrate	AnalysisNarrativePanel
/api/die/investigation-results	POST	{input}	{object: {narrative, mitre[], iocs, lolbas, chain, csv_edr, incident_tactics, health, ida, ...}} (250 KB cap enforced by test_investigation_results_payload_shape)	routers/die.py::die_investigation_results	InvestigationResult + TrajectoryDiagram fallback
/api/analyze	POST	{input, output?, enrich_osint?, use_ai_verdict?, describe?}	{iocs, mitre[], mitre_provenance{}, yara, lolbas, risk, osint, ti_hits, ti_lookup_meta, ai_verdict?, description?, corrupt_payload?}	routers/analyze.py::analyze	Not called by primary Investigate button; used by /analyst/v2 flows
/api/analyze/async	POST	{input, ...}	{job_id}	routers/analyze.py::analyze_async_submit	analyze_async_submit
/api/analyze/status	GET	{job_id}	{status, result?}	same file	polling

/api/behavioral/psocn	POST	{xml, case_id?}	envelope (adapter, evidence, parent_child_evidence, network_evidence, per_event_mitre, mitre_technique_ids, mitre_provenance, limitations)	routers/behavioral.py	BehavioralTimelineIngest
/api/behavioral/psocn/evtx	POST	{evtx_base64, case_id?}	same envelope + transport{}	routers/behavioral.py	BehavioralTimelineIngest
/api/behavioral/attach (this session)	POST	{case_id, envelope}	{case_id, attached_at, updated_at, adapter_history[]}	routers/behavioral.py	BehavioralTimelineIngest (server-side but Workspace could call)
/api/behavioral/case/{case_id}	GET	—	{case_id, user_email, envelope, attached_at, updated_at, adapter_history[] or 404}	same	BehavioralTimeline hydrate
/api/behavioral/case/{case_id}	DELETE	—	{deleted, case_id}	same	BehavioralTimeline detach
/api/cases/save	POST	{name, input, output, engine, confidence, chain_ids, verdict, iocs, ssot}	{id, name, created_at, updated, reinvestigated}	routers/cases.py	Workspace saveCase
/api/cases/{case_id}	GET	—	full case doc + ssot_source, artifact_trace, acquisition_summary, acquisition_ocr_records	routers/cases.py	Workspace Restore from History
/api/history/{id}	GET	—	{input, decoded, ...}	routers/history.py	History Drawer
/api/report/{fmt}	POST	{input, output, mitre, iocs, engine, chain, verdict, confidence}	file (PDF / Markdown / STIX / Sigma / YARA / Navigator / MDR)	routers/reports.py	ReportMenu
/api/session/fromInvestigation	POST	{input, session}	session bundle	routers/sessions.py	InvestigationSessionGateway
/api/threat-intel/enrich-batch	POST	{iocs}	enriched	routers/threat_intel.py	ThreatAnalysis

11.1 Transformation points

- **Ingress-gate normalisation:** vendor JSON telemetry → plain text
(`nivxforge.investigation.ingress_gate.apply_ingress_gate`) — happens INSIDE `/api/decode/smart` and preserves the response shape.
- **DIE envelope → augmentation:** `services/die/canonical_bridge.augment_die_result` adds fields to `result.techniques` and `result.chain.steps[0].techniques` from narrative rules. Additive-only.
- **Slim response gate:** `_slim_investigation_response` on `/api/die/investigation-results` strips `preprocessor / commands / artifacts / explanations / ...` from the wire response. Locked by `test_investigation_results_payload_shape` (250 KB cap).
- **Verdict card → risk projection:** `verdict_projection.derive_risk_projection` remaps `verdict_card` fields to legacy `risk`.

§12 Persistence map

Object	Collection	Producer	Reader	UI consumer
Workspace case	<code>workspace_cases</code>	<code>/api/cases/save</code>	<code>/api/cases/{id}</code> , <code>/api/cases</code>	Case Library, Workspace restore
Canonical investigation SSOT	<code>investigation_ssot</code> (content-addressable)	<code>services/ssot_store</code>	<code>services/ssot_store</code>	<code>load_ssot</code> <code>/api/cases/{id}</code>
Behavioral evidence (this session)	<code>behavioral_evidence</code>	<code>/api/behavioral/*</code> (auto-attach) or <code>/api/behavioral/attach</code>	<code>/api/behavioral/cases/{behavioral_id}</code>	Behavioral timeline
Investigations	<code>investigations</code> (via <code>db.investigations</code> — 28 hits)	Various UIL / IEDDE paths	<code>/api/investigations/*</code>	Investigation drawer
IOCs	<code>iocs collection</code>	Various	<code>/api/ioc-intelligence/*</code>	IOC panel
Correlations	<code>correlations</code>	<code>services/correlation</code>	<code>/api/correlations/*</code>	Find Related Cases
Learning events	<code>learning_events</code> (9 hits)	<code>/api/learning*</code>	admin	admin dashboards
Analyst corrections	<code>analyst_corrections</code>	<code>/api/analyst/corrections</code>	admin	admin
Sample library	<code>sample_library</code> , <code>samples</code>	seeded	<code>/api/samples/*</code>	XLAB
Regression corpus	<code>regression_corpus</code>	<code>/api/regression/*</code>	admin	admin
Frontend telemetry	<code>frontend_telemetry</code>	<code>/api/telemetry</code>	admin	admin
Files (GridFS)	<code>fs.files</code> , <code>fs.chunks</code>	<code>services/files/store</code> <code>open_read</code> <code>re.put</code>		<code>/api/upload</code> response
AI describe cache	<code>ai_describe_cache</code>	<code>/api/analyze</code> (AI leg)	same	<code>/api/analyze</code>
AI decode cache	<code>ai_decode_cache</code>	<code>/api/decode*</code> (AI cache)	same	same
Shares	<code>shares</code>	<code>/api/share</code>	<code>/api/share/{id}</code>	share URL

Users	users	/api/auth/register, /api/auth/login	login flow	Auth
TI source metadata	ti_source_meta	TI providers	providers	—
RSS metadata	cti_rss_meta	/api/threat-intel-rss	same	—
Analyze jobs	analyze_jobs	/api/analyze/async	/api/analyze/status/ <code>Workspace</code>	Workspace
Frontend localStorage	—	useIdlePersist (heavy fields removed)	WorkspacePage restore	Workspace
ADR / memory files	filesystem /app/memory/adr/	manual (edits)	dev reference	— (out of app)

§13 External dependencies

Dependency	Nature	Where it enters
MongoDB (Motor async + PyMongo sync)	DETERMINISTIC storage (non-deterministic ordering unless sort=)	Everywhere
Filesystem (GridFS)	DETERMINISTIC (via GridFS)	/api/upload
Redis	NOT DETECTED in the routers/services grep — appears in build tooling only	—
Emergent LLM key (Claude / GPT / Gemini)	EXTERNAL / NON-DETERMINISTIC	/api/analyze (AI describe), /api/die/narrate (LLM disabled here, deterministic only)
TI feeds (bounded 500 ms)	EXTERNAL / NON-DETERMINISTIC (with ti_lookup_meta provenance)	analysis_core.lookup_ti_hits_bounded_met
OSINT providers	EXTERNAL / NON-DETERMINISTIC (bounded 20 s)	analysis_core.enrich_iocs
DNS	NOT USED for verdicts (only Sysmon reverse-lookup fields are surfaced as advisory)	—
VirusTotal / equivalent	routed through OSINT	same
Subprocesses	Only via python-evtx in-process	services/behavioral/evtx_reader.py
defusedxml	DETERMINISTIC	Sysmon adapter
pdfplumber / pypdfium2 / pymupdf / xhtml2pdf	DETERMINISTIC	Report generation, PDF text extraction
chromium	Installed in container (for headless tests)	not in production pipeline

§14 Legacy vs modern architecture

14.1 Side-by-side

Concern	LEGACY	MODERN	Live wire path today
Command decoding	<code>smart_decoder.smart_decode</code> + <code>magic_decode</code> (bounded search)	<code>services/die/api.analyze</code> + <code>recursive_decode</code>	Legacy on <code>/decode/smart</code> ; modern on <code>/die/*</code>
MITRE mapping	<code>operations.mitre_map</code> (regex)	<code>services/die/api::_analyze</code> + LOLBAS + recursive-decode merge + P0.2 gate → <code>get_authoritative_mitre</code>	Legacy still owned inside <code>verdict_card</code> ; modern only on <code>/api/analyze</code>
Verdict scoring	<code>operations.risk_score</code> (recalibrated Item-1)	(shadow) Verdict Engine v3	Legacy live; modern shadow
Narrative	<code>Legacy narrative.py</code> stage generator	<code>services/die/canonical_narrative_composer.canonical</code>	Both compose; canonical fills legacy when empty
Attack Chain	6-lane legacy <code>AttackGraph</code>	14-tactic <code>TrajectoryDiagram</code> (UI-DEF-02)	Both mounted (legacy hidden when trajectory renders)
Case save	Inline <code>ssot</code> bundle	Content-addressable <code>investigation_ssot</code> store + <code>ssot_ref</code> pointer	Write-through: both are live
Correlation	none in decode path	<code>services/correlation_engine.correlate</code> <code>services/ice.correlate.enrich_clusters_in_place</code> (only on <code>/api/cases/{id}</code> read)	Modern only
Behavioral	none	Sysmon Event 1/3 adapter + EVTX transport + persistence (this session)	Modern only
Router entry point	<code>/api/decode/smart</code> (primary)	<code>/api/ui/investigate</code> (canonical, flag ON — but NOT called by Workspace)	Legacy still primary

14.2 Migration gaps

- **Gap G1:** Workspace primary submit still on `/api/decode/smart`. Verdict card + mitre[] therefore come from the legacy pipe. Direct evidence: saved `PrevMode` case has `engine: rc2-orchestrator`, `mitre: [T1027 regex-only]`.
- **Gap G2:** `/api/ui/investigate` canonical entry is flag-enabled (`NIVX_CANONICAL_UIL_INVESTIGATE=on`) but the Workspace does NOT route to it. It is currently used only for external `/ui/investigate` testing.
- **Gap G3:** Shadow subsystems (Trajectory Engine, Case Engine, Adapters, Artifact Store, Verdict Engine v3) are all `NIVX_FLAG_*=shadow` in `.env`. Per ADR-0008 they must remain shadow until validation replay passes.
- **Gap G4:** Legacy `operations.mitre_map` regex is still consulted inside the primary path — it is the entire MITRE source for `PrevMode`-class cases.
- **Gap G5:** Behavioral evidence is not fed into `risk_score`; the two lanes are wired only for UI highlight.

14.3 Duplicates

- **MITRE mapping:** 3 producers (regex, DIE catalogue, canonical narrative) + 1 gate resolver. AI leg can add a 4th.
- **Verdict:** `risk_score` × `build_verdict_card` × shadow v3.

- **Attack Chain:** AttackGraph (legacy 6-lane) + TrajectoryDiagram (14-tactic).
- **Narrative:** legacy stage-generator + canonical_narrative_enrichment.

14.4 Still-active dead-ish code

- operations.mitre_map (regex) — actively fires for every /decode/smart call.
- AttackGraph — imported but usually hidden.
- Legacy AnalystNarrativePanel mitre_matrix regrouping — dead branch when narrative bridge fills a proper matrix.

§15 Five end-to-end input journeys

A · Python command line (the PrevMode case)

```
INPUT -c "exec(base64.b64decode(b'...').decode())" afbtDVtsqwFyVTx ■ ROUTER /api/decode/smart
(Workspace Investigate default) ■ ADAPTER ingress_gate (no vendor JSON → passthrough)
_atomic_ioc_kind (not atomic → passthrough) ■ ANALYZER deterministic_best_decode ■■■
rc22_adapter.try_orchestrator_first (RC2.2 preflight) ■■■ smart_decode (peels 1 base64 layer →
prints Python source) ■■■ magic_decode (competes; winner returned) ■ DECODER chain:
extract-payload → base64-decode → cmd-runtime-reconstruct (STOPS at layer 1) ■ ARTIFACT
DISCOVERY extract_iocs → { urls:[], ips:[], ... } (no external IOC in Python source) scan_lolbas →
[] (python.exe not on curated LOLBAS list) yara_lite_scan → { Base64_Long_Blob } ■ EVIDENCE none
in canonical sense (regex hits only) ■ CORRELATION (none – atomic IOC guard did not fire but no
correlator runs here) ■ MITRE operations.mitre_map (regex): matches "long base64 blob" pattern →
T1027 (Defense Evasion) NEVER reaches DIE catalogue on this path Missing: T1059.006, T1027.013,
T1140, T1036.008, T1620 ■ VERDICT risk_score({T1027}, yara-low, iocs={}, lolbas=[]) = 5(mitre) +
4(yara low) + 8(T1027 not in high-signal list → 0) ≈ 65 (Suspicious) [confirmed matches saved
case] ■ NARRATIVE parallel /die/narrate call – canonical enrichment for T1027 only ■ PERSISTENCE
/cases/save → workspace_cases + investigation_ssot pointer ■ WORKSPACE UI: Verdict card:
"Suspicious · 65" MITRE: T1027 (regex – Standalone long base64 blob) Chain: extract-payload →
base64-decode → cmd-runtime-reconstruct LOLBAS: [] IOC: {} (all empty) Behavioral: (empty – no
Sysmon paste)
```

Where this path differs from the ideal: it never enters services/die/api.analyze, so the DIE catalogue never sees the input; the LOLBAS registry never sees python; recursive-decode never re-runs on the peeled Python. All 5 missing techniques originate from that omission.

B · PowerShell -EncodedCommand

Same router. Difference: - smart_decode peels the -Enc <b64>, services/die/api.analyze fires on both the outer command AND the peeled inner via _apply_recursive_decode (matches -EncodedCommand regex in recursive_decode._B64_PATTERNS). - Result: T1059.001 (Powershell) + T1027 + T1140 (from recursive decode) + T1105 (if URL in inner) + possibly LOLBIN hits. - Verdict often lands in Malicious ≥70 due to the recursive-decode bonus + high-signal TTPs.

C · Sysmon E1 + E3

```
INPUT analyst paste of Sysmon XML into BehavioralTimeline ■ ROUTER /api/behavioral/sysmon ■
ADAPTER services/behavioral/sysmon_adapter.normalize_sysmon_xml ■ ANALYZER (none – evidence
producer only) ■ DECODER (n/a) ■ ARTIFACT DISCOVERY per Sysmon field → canonical evidence record
parent-child pair with corroboration network connection (IPv4/IPv6 canonicalised) destination
classification (RFC1918 / reserved) ■ CORRELATION tri-state: RESOLVED / UNRESOLVED_DANGLING /
AMBIGUOUS_PID_ONLY deduplication on (ProcessGuid, protocol, canon_dst_ip, dst_port, initiated) ■
```


MITRE run `\_authoritative\_techniques(command\_line)` on each E1 → hands to `services.die.api.analyze` → DIE catalogue → `per\_event\_mitre[]` on the envelope E3 alone emits NO authoritative techniques (locked by test). ■ VERDICT (n/a – behavioral evidence does NOT feed risk_score today) ■ NARRATIVE (n/a in behavioral panel – but visible in the MITRE handoff line) ■ PERSISTENCE (this session) auto-attach if case_id provided → behavioral_evidence collection ■ WORKSPACE UI: E1 rows with "supports · T1105, T1140, ..." E3 rows with correlation-state chip, dedup badge, "via E1 · T..." Evidence Inspector Advisory fields block (confidence: advisory) MITRE handoff footer [click a chip → nivx:mitre-selected → Attack Chain highlights] [click an E1/E3 row → nivx:evidence-selected → Attack Chain highlights]

D · EVTX containing E1+E3

Same as C. Differences: - Enters `/api/behavioral/sysmon/evtx`, decoded by `services/behavioral/evtx_reader.decode_evtx_to_sysmon_xml` (python-evtx 0.8.1) → wrapped `<Events>` → same normalizer. - Response envelope adds transport: { transport: 'evtx.transport@1.0', record_count: N }. - Everything downstream identical to C.

E · Office / DOCX vendor narrative

INPUT analyst uploads Sample.docx ■ ROUTER `/api/upload` ■ ADAPTER `FileStore.put` (streaming sha256, GridFS) `input_router.route_for(header, mime, name)` → "office" ■ ANALYZER (in-router) `safe_iter_zip_members` → extract text from `word/document.xml`, `ppt/slide*.xml`, `xl/sharedStrings.xml` ■ DECODER (n/a – plain narrative prose) ■ Subsequent parallel Workspace calls: `POST /decode/smart` → text goes through the same command pipeline `POST /die/investigation-results` → `augment_investigation_results` ■■■ canonical_bridge narrative MITRE rules (T1219, T1204.002, T1071, T1486, T1003, T1566) ■■■ csv_edr_analyzer (no-op for prose) ■■■ enrich_narrative populates executive_summary, attack_progression, recommended_actions, LOLBAS.legit/abuse/detection → `_slim_investigation_response` (drop heavy fields, ≤250 KB) `POST /die/narrate` → mirrors the same enrichment ■ EVIDENCE narrative techniques carry an `evidence` prose snippet from the paste ■ CORRELATION ICE cluster enrichment on read ■ MITRE authoritative on ``/analyze`` when consulted; canonical narrative on ``/die/*`` ■ VERDICT risk_score across the merged signals – commonly Malicious 100 for real IR reports ■ NARRATIVE full analyst brief ■ PERSISTENCE case_save with full SSOT bundle → `workspace_cases` + `investigation_ssot` ■ WORKSPACE UI: full 14-tactic Attack Chain + narrative panel + IOCs + Attack Story chapters

Where paths diverge: A (Python) and E (Office narrative) both use `/decode/smart` as the primary path, but A only gets regex MITRE while E benefits from canonical_bridge narrative MITRE because the augment path fires on prose. B and C/D each use a completely different adapter chain.

§16 Failure / empty-result modes

Symptom	Root cause	Location	UI behaviour
No verdict	Empty input	<code>/decode/smart</code> short-circuits on empty	Workspace shows placeholder
No MITRE	Regex mapper didn't match AND <code>/die/analyze</code> returned empty <code>techniques[]</code>	E.g. Python without base64, or novel loader	Empty MITRE panel

No Attack Chain graph	<code>investigationObject.chains == [] AND inlineStoryPreproc empty AND incidentBehaviors == []</code>	<code>inTrajectoryDiagram</code> early-return check	Section not rendered
No narrative	<code>AnalystNarrativePanel.hasContent</code> after Phase 5.W all-empty (executive_summary / behavior_summary / attack_progression / mitre_matrix all empty)	canonical enrichment	Panel <code>null</code>
Empty Timeline	No high-conf events extracted	<code>services/die/investigation</code>	Section hidden
Empty Behavioral Timeline	No Sysmon paste or EVTX drop for the current case	<code>BehavioralTimeline</code> no-op	"No behavioral events emitted." (this session's persistence layer rescues subsequent reloads)
"Page Unresponsive"	Chrome 15 s freeze from <code>JSON.stringify(investigationObject)</code> on the main thread	<code>useIdlePersist</code> snapshot	Fixed by Phase 5.W · P0.c dropping heavy fields
"Corrupt payload" flag	<code>detect_corrupt_payload</code> positive	<code>/api/analyze</code>	Warning banner
TI timeout	<code>ti_lookup_meta.status = timeout</code>	<code>lookup_ti_hits_bounded</code> media (500 ms cap)	Diagnostic chip in verdict card; verdict unchanged
AI describe timeout	<code>_AI_DEADLINE_S</code> exceeded	<code>/api/analyze</code>	Negative cached for 10 min, banner shown
Verdict under-called	Legacy path used; regex mapper only fires one broad T1027	<code>/decode/smart</code> primary path	Direct evidence: <code>PrevMode</code> case
Decoded output missing ^ (this session's finding)	Character stripping somewhere between decoded bytes and displayed text; not verified from code — needs a reproduction test	<code>/decode/smart</code> output rendering OR JSON encoding OR HTML escape	<code>PrevMode</code> output shows <code>gzqtmkvvskjzafjjof</code> instead of <code>gzqtmkvv ^ skjzafjjof</code>

NOT VERIFIED FROM CODE: exact strip site of the ^ character. Verified only via a live decode reproduction of the `PrevMode` payload.

§17 Security boundaries

Boundary	Mechanism	Location	Notes
Authentication	JWT bearer (Authorization: Bearer <token>) via <code>deps.get_current_user</code>	<code>deps.py</code>	Login rate-limited (5 fail → 15-min lockout · ADR-0010b)

Authorization	Currently role-agnostic on the routes the Workspace uses; every route requires auth	routers	ADMIN-only routes exist in <code>admin.py</code>
File-size limit	<code>NIVX_FILES_MAX_UPLOAD_BYTES</code> default 200 MB	<code>services/files/store.py</code>	413 fail-loud
XML XXE	defusedxml everywhere Sysmon XML is parsed	<code>services/behavioral/sysmon_adapter.py</code>	61243 <code>NIVX_SYSMON_MAX_BYTES</code>
ZIP bomb	<code>safe_iter_zip_members</code> — depth / entry count / expanded size / per-entry / ratio / path safety	<code>security/archive_guard.py</code>	ADR-0010b P0 gate
CORS	Explicit origin list (not <code>["*"]</code>)	<code>security/cors.py</code>	ADR-0010b P0 gate
Rate limit (login)	5 fails/15 min	<code>security/rate_limit.py</code>	ADR-0010b P0 gate
EVTX size cap	16 MiB <code>NIVX_EVTX_MAX_BYTES</code> , 10 000 records <code>NIVX_EVTX_MAX_RECORDS</code> , magic check	<code>services/behavioral/evtx_adapter.py</code>	413400 fail-loud
Sysmon EID3 cap	<code>NIVX_SYSMON_EID3_MAX_EVENTS</code> default 5000	<code>services/behavioral/sysmon_adapter.py</code>	413
Subprocess isolation	NONE — parsers run in-process (open architectural risk ADR-0010b)	—	PLANNED (locked)
SSRF	TI/OSINT calls run through providers that use explicit allow-list URLs	provider modules	not comprehensively audited
Uploaded-file handling	Content-magic-first routing, filename never trusted alone	<code>input_router.route_for</code>	ADR-0008 §5.2
Behavioral evidence scoping	<code>user_email + case_id</code> on every read/write	<code>routers/behavioral.py</code> (this session)	Verified by <code>test_workspace_isolation_across_</code>

§18 Determinism map

Layer	Deterministic?	Source of non-determinism
DIE analyzer catalogue	■	—
Recursive decode	■	—
LOLBAS registry	■	—
Regex mapper	■	—
risk_score	■	—
Sysmon adapter	■	—

EVTX transport	■ (in-file record order preserved)	—
Behavioral persistence	■ (round-trips envelope)	—
Ingress-gate JSON normalisation	■	—
Reports (Markdown/STIX/YARA/Sigma/Navigator/MDR)	■	Locked by test_report_determinism.py
PDF report	■■ Deferred (per ADR-0008)	—
TI lookups	■ external	ti_lookup_meta.status (bounded)
OSINT enrichment	■ external	bounded 20 s
AI describe / AI verdict	■ LLM	Cached; negative timeout cached 10 min
Case UUIDs	■	uuid.uuid4() on insert
DNS reverse	■	Only surfaced as advisory
Correlation cluster order	partial	Deterministic within a case but between reads relies on Mongo order
Workspace UI order	■	Sorted arrays server-side

§19 Architectural gaps (evidence-cited, no proposed fixes)

P0 correctness - G-P0-1 · Primary Workspace /api/decode/smart bypasses the UI-DEF-02 authoritative MITRE surface. Evidence: routers/ops.py:decode_smart never calls get_authoritative_mitre; PrevMode saved case has engine=rc2-orchestrator, mitre=[T1027 (regex)]. - G-P0-2 · Legacy operations.mitre_map regex still fires inside evidence_extractor.build_verdict_card even on UI-DEF-02-aware routes; verdict card cannot benefit from the modern catalogue. - G-P0-3 · Decoded-output ^ XOR character stripping. Manifests in PrevMode.output where the peeled Python source drops the ^ operator (gzqtmkvvsjkzafjjof[...] vs actual gzqtmkv ^ skzafjjof[...]). Root cause NOT VERIFIED FROM CODE — reproduction is available but no code-side site of the strip is confirmed. - G-P0-4 · Recursive-decode _B64_PATTERNS recognises PowerShell -Enc / .NET FromBase64String / bash base64 -d, but NOT Python base64.b64decode(...). A python -c "exec(base64.b64decode(...))" therefore never triggers recursive decode.

P1 architecture - G-P1-1 · Two independent verdict engines (risk_score + shadow v3). Shadow subsystems all NIVX_FLAG_*=shadow; validation-replay path exists but is not run. - G-P1-2 · Behavioral evidence has no path into the primary verdict engine. Timeline evidence and Attack Chain converge only in the client-side highlight. - G-P1-3 · No cross-source correlator. Sysmon-only path is the sole "behavioral" input. - G-P1-4 · Workspace canonical entry (/uil/investigate) is flag-ON but the Workspace does not call it. Phase 5.1 → 5.8 sequencing gate blocks the switch.

P2 functionality - G-P2-1 · Multiple structured telemetry sources are unsupported: WMI, Syslog, firewall, DNS, web/DB/server logs. Classifier has kinds for some (PCAP, EVTX non-Sysmon) but no analyzer. - G-P2-2 · Email adapter absent — input_router returns "email" but there is no services/*/email_adapter.py. - G-P2-3 · PE analyzer runs on upload but does not contribute to verdict. - G-P2-4 · Python analyzer lacks T1059.006 mapping, T1027.013 (encrypted/encoded file), T1620 (reflective code load), and does not detect XOR-decrypt patterns. - G-P2-5 · No filename / crypto-key IOC classes; the current IOC scheme (urls, ips, domains, emails, hashes, bitcoin_addresses) cannot record the instructions.docx filename or the 25-byte XOR key from PrevMode. - G-P2-6 · Attack Chain auto-scroll / focus on evidence click — planned (Task 3 on hold).

P3 UX - G-P3-1 · AttackGraph (legacy 6-lane) still ships alongside TrajectoryDiagram (modern 14-tactic). Dead code risk. - G-P3-2 · Trailing junk / campaign markers after commands (afbtdVtSqWfyvTx in PrevMode) are silently dropped

by decoders. No "unparsed trailing content" surface.

Future - F-1 · Sandbox parser boundary (subprocess isolation for PE/DOCX/shellcode parsers) — ADR-0010b-planned, LOCKED until other stabilisation completes. - F-2 · Real Investigation Proof Phase B (human trial) — LOCKED. - F-3 · Verdict Engine v3 promotion — LOCKED behind shadow-replay validation.

§20 "What is authoritative" · "What is legacy" · "What is implemented vs planned"

20.1 Authoritative today

Surface	Owner	Locked
MITRE on /api/analyze	analysis_core.get_authoritative_mitre → DIE catalogue + P0.2 gate	ADR-0010m/o/p
MITRE on /api/die/analyze	DIE catalogue via _analyze_single + _merge_lolbin_techniques + _apply_recursive_decode	ADR-0010p
14-tactic Attack Chain UI	TrajectoryDiagram.jsx	ADR-0010m
Behavioral evidence (Sysmon E1/E3)	services/behavioral/sysmon_adapter.py	ADR-0010q/r
EVTX transport	services/behavioral/evtx_reader.py	ADR-0010s
Behavioral Timeline persistence	routers/behavioral.py + behavioral_evidence collection	ADR-0010v (this session)
Verdict scoring	operations.risk_score (recalibrated Item-1)	ADR-0010f
Report determinism	Locked by test_report_determinism.py	ADR-0008
Sample1 immutability	Locked by test_sample1_immutability_guard.py	ADR-0008
Workspace ↔ XLab isolation	Locked by isolation tests	ADR-0008
CI payload-shape gate (≤250 KB)	Locked by test_investigation_results_payload_shape.py	Phase 5.W · P0.a

20.2 Still legacy

Surface	Location	Reason still live
/api/decode/smart primary path	routers/ops.py::decode_smart	Workspace still calls it as the main Investigate route
operations.mitre_map() regex mapper	operations.py:2900	Still called by verdict card builder
evidence_extractor.build_verdict legacy verdict path	evidence_extractor.py:524	Still primary for Workspace-saved cases
Legacy 6-lane AttackGraph	frontend/src/components/AttackGraph.jsx	Still supported (usually hidden)

Legacy stage-generator narrative (services/die/narrative.py)	narrative.py	Runs before canonical enrichment fills empties
smart_decode + magic_decode	smart_decoder.py, magic_decode.py	Foundation of deterministic_best_decode

20.3 Implemented vs planned vs documented-but-not-implemented

Item	State
P0 Security Hardening Gate	■ IMPLEMENTED (ADR-0010b)
P1 Server-Side File Mode	■ IMPLEMENTED (ADR-0010c)
P1.1 Upload-bridge (Workspace → FileStore)	■ IMPLEMENTED (ADR-0010d)
Real Investigation Proof Phase A	■ COMPLETED as REDIRECT (ADR-0010e)
Remediation Items 1–5 (risk-score / narrative / recursive-decode / T1562.004 / TI-latency)	■ IMPLEMENTED (ADR-0010f/g/h/k/l)
UI-DEF-02 MITRE Convergence + LOLBIN extension	■ IMPLEMENTED (ADR-0010m/o/p)
P2 Slice-1 · Sysmon Event 1	■ IMPLEMENTED (ADR-0010q)
P2 Slice-2 · Sysmon Event 3	■ IMPLEMENTED (ADR-0010r)
P2 Slice-3 · EVTX transport	■ IMPLEMENTED (ADR-0010s) — test uses mocked <code>Evtx.records()</code> (Task 2 P0 stabilisation)
P2 UI Slice-1 · Behavioral Timeline projection	■ IMPLEMENTED (ADR-0010t)
P2 UI Slice-2 · Attack Chain ↔ Evidence bidirectional	■ IMPLEMENTED (ADR-0010u)
P2 UI Slice-3 · Timeline persistence	■ IMPLEMENTED THIS SESSION (ADR-0010v)
Real EVTX fixture in Slice-3 test	■■ PLANNED (Task 2 on hold)
Attack Chain auto-scroll on evidence click	■■ PLANNED (Task 3 on hold)
Source-agnostic contract audit	■■ PLANNED (Task 4 on hold)
P2 Slice-4 · Sysmon Event 22 DNS	■ LOCKED
P2 Slice-5 · Sysmon Event 11 File Create	■ LOCKED
Sandbox parser boundary (subprocess isolation)	■ LOCKED
Real Investigation Proof Phase B (human trial)	■ LOCKED
Verdict Engine v3 promotion	■ LOCKED behind shadow-replay
Trajectory Engine / Case Engine / Adapters / Artifact Store promotion	■ SHADOW (per <code>NIVX_FLAG_*=shadow</code> in <code>.env</code>)
Workspace routing to <code>/u1l/investigate</code> canonical entry	■ NOT authorised (Phase 5 sequencing)
Non-Sysmon behavioral adapters (WMI/Syslog/firewall/DNS/EDR structured)	■ NOT YET SCOPED (Task 4 audit will document contract)

Email adapter	■■ DOCUMENTED (Input Router routes to "email") but NOT IMPLEMENTED
PDF adapter (structured)	■■ text extraction only; no PDF-specific analyzer
STIX / OpenIOC / YARA / Sigma consumers	■■ CLASSIFIED but NOT ANALYZED
PCAP consumer	■■ CLASSIFIED, no analyzer
Image adapter	■■ ROUTED, no analyzer
PPID spoofing kernel-callback ETW (T1134.004 corroboration)	■■ DOCUMENTED as limitation, not implemented
TweetFeed integration (A/B/C)	■■ BACKLOG (ADR-0011)

Most-important-rule confirmation

- No file was modified during this audit.
- No test was added or changed during this audit.
- No memory / ADR / PRD other than this new 0012-workspace-360-audit.md was created.
- No architecture was proposed. Only current state was documented, with file/function citations.
- Task 2 (Real EVTX fixture), Task 3 (Attack Chain auto-scroll), Task 4 (Source-agnostic audit) remain **PLANNED / ON HOLD** and are not started.
- Global locks (Sysmon E22, E11, sandbox boundary, Phase B, Verdict v3, Case Engine, Server-Side File Mode expansion) remain intact.

End of audit.